MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Controlling Access to Network Resources with User-ID

Unit 12 · Information Security 2 (10-151-111)

MID-STATE TECHNICAL COLLEGE

Learning Outcomes

By the end of this unit, you will be able to:



Identify the purpose and components of User-ID

Explain why identity beats IP addresses, and name the four User-ID components.



Identify user mapping methods

Compare the ways the firewall learns who is behind an IP address, and pick one.



Configure the PAN-OS integrated User-ID agent

Enable User-ID per zone, add monitored servers, and verify the connection.



Configure username-to-group mapping

Connect to LDAP, set username attributes, and filter or build groups.



Implement User-ID in Security policy

Match on users, groups, and Dynamic User Groups, and verify the result in the logs.

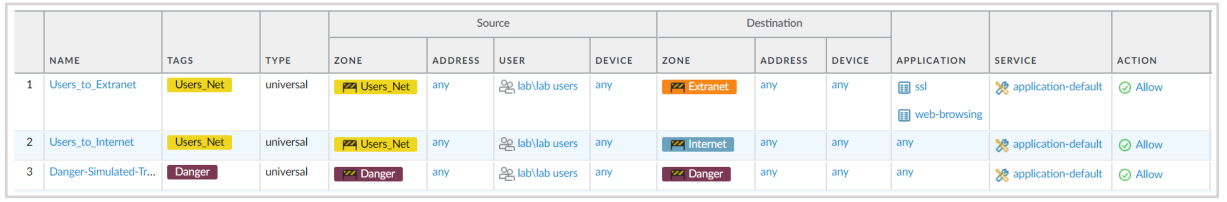
LESSON 1

User-ID Overview

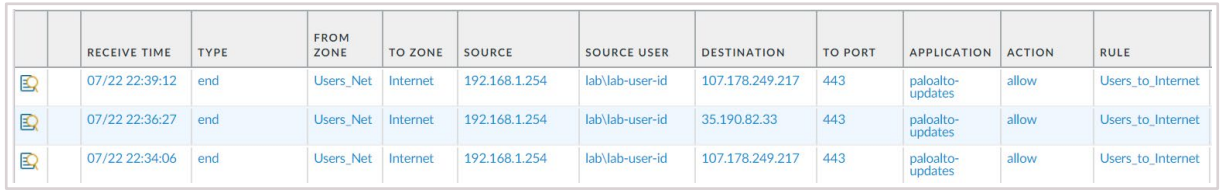


Know the Who, Control the Who

- An IP address tells you which **machine** sent traffic, not who was sitting at it, and addresses change with DHCP, VPNs, and roaming.
- **User-ID** lets you write policy, view logs, and run reports with **usernames and group names** instead of only addresses and ports.
- Combined with **App-ID**, it controls which users can reach which applications from which zones.
- Usernames show up in **Policies > Security** and **Monitor > Logs > Traffic**.



	NAME	TAGS	TYPE	Source				Destination			APPLICATION	SERVICE	ACTION
				ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE			
1	Users_to_Extranet	Users_Net	universal	Users_Net	any	lab\lab users	any	Extranet	any	any	ssl web-browsing	application-default	Allow
2	Users_to_Internet	Users_Net	universal	Users_Net	any	lab\lab users	any	Internet	any	any	any	application-default	Allow
3	Danger-Simulated-Tr...	Danger	universal	Danger	any	lab\lab users	any	Danger	any	any	any	application-default	Allow



		RECEIVE TIME	TYPE	FROM ZONE	TO ZONE	SOURCE	SOURCE USER	DESTINATION	TO PORT	APPLICATION	ACTION	RULE
		07/22 22:39:12	end	Users_Net	Internet	192.168.1.254	lab\lab-user-id	107.178.249.217	443	paloalto-updates	allow	Users_to_Internet
		07/22 22:36:27	end	Users_Net	Internet	192.168.1.254	lab\lab-user-id	35.190.82.33	443	paloalto-updates	allow	Users_to_Internet
		07/22 22:34:06	end	Users_Net	Internet	192.168.1.254	lab\lab-user-id	107.178.249.217	443	paloalto-updates	allow	Users_to_Internet

Top: a Security policy rule matching a user group. Bottom: the Traffic log with the Source User column.

User-ID Does Two Jobs

User mapping

- Associates **IP addresses** with **usernames**
- Learned from many sources: domain controllers, GlobalProtect, syslog, the XML API
- Changes constantly as users log in, log out, and move

Group mapping

- Associates **usernames** with **group names**
- Learned from an **LDAP** directory such as Active Directory, or the XML API
- Lets you write one rule for a whole department

Not just Security policy: Users and groups also work in Authentication, Decryption, DoS Protection, Policy-Based Forwarding, QoS, SD-WAN, and Tunnel Inspection policies.

The Four User-ID Components

Every User-ID deployment is built from some combination of these four pieces:

Component	What it does
Palo Alto Networks firewall	Maps IP addresses to usernames and usernames to group names
PAN-OS integrated agent	Runs on the firewall itself and collects IP address-to-username information
Windows-based agent	Installed on a domain member; collects mappings and sends them to the firewall
Terminal Services agent	Runs on Microsoft and Citrix terminal servers; maps IP and port to username

A firewall can use both agent types at the same time. Each agent monitors up to 100 servers in a single Active Directory domain.

Integrated Agent vs. Windows-Based Agent

Same job, different protocols, which makes each a better fit for different sites:

	PAN-OS integrated agent	Windows-based agent
Protocol	WMI or WinRM over HTTP/HTTPS	MS-RPC
What it pulls	Only the relevant login events	Full Windows Security logs, filtered at the agent
Best for	Small and midsize sites, labs, reading across a WAN	Large or multi-forest networks, reading local logs
Cost	Uses firewall management-plane resources	Needs a Windows server, but offloads the firewall

Common design: Windows agents at remote sites forward mappings to a firewall on the central network.

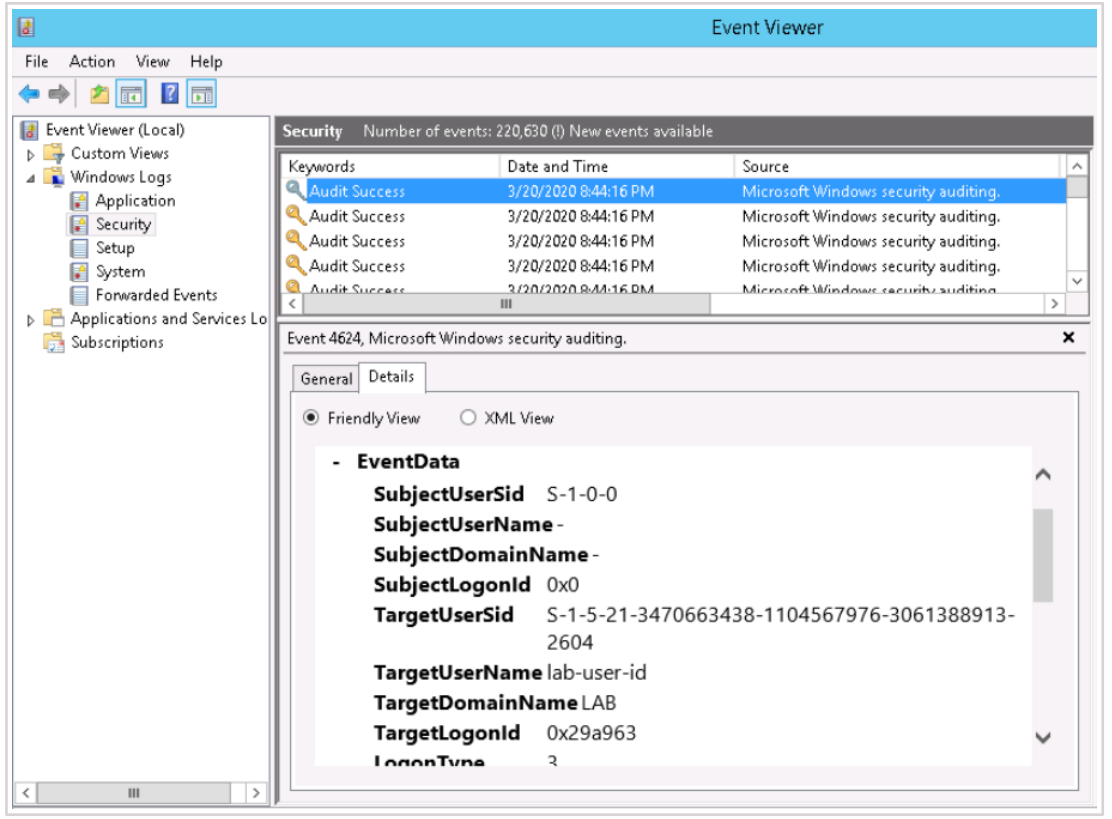
LESSON 2

User Mapping Methods



Server Monitoring: The Base Method

- The agent reads **login and logout events** from the Security logs of domain controllers, Exchange, or eDirectory servers.
- Low overhead and maps most users, so it is the **recommended base method** for most deployments.
- Monitor **every** domain controller: users can log in to any of them, and Security logs are not replicated.
- The domain must be set to **audit successful logons**, or there is nothing to read.



Session Monitoring and Client Probing

Session monitoring

- Reads the session table for **Windows file and print shares**
- Used to **confirm** existing IP-to-user mappings
- Cheap, but only sees users who touch a share

Client probing (WMI)

- The agent **probes** Windows clients to see who is logged in
- Catches users whose IP changes often, and unmapped addresses get an immediate probe
- Designed for older Windows-only networks; less useful with roaming and mobile users

Probing has a cost: every probe is network traffic and uses agent credentials on the client. Enable it only when server monitoring leaves real gaps.

GlobalProtect and Captive Portal

- **GlobalProtect** requires every user to log in to connect, then adds the username straight to the firewall's mapping table.
- Works for remote VPN users and for internal users through an **internal gateway** with no tunnel.
- **Captive Portal** redirects web traffic from unidentified users to a login form.
- Use it for clients that never log in to the domain, such as Linux hosts or guest devices.



SECURITY FOCUS

Log-based methods infer who is at an address. GlobalProtect knows, because the user authenticated to get on the network.

Why it matters: When access to a sensitive app depends on identity, a guessed mapping is a gap an attacker can stand in.

Syslog, Terminal Services, and the XML API

For devices and systems that a domain controller never sees:

Method	How it works	Use it for
Syslog listener	Parses login and logout messages using Syslog Parse Profiles	Wireless controllers, 802.1x, NAC, proxies, Unix/Linux
Terminal Services agent	Maps IP address and port ranges to each user session	Remote Desktop Services and Citrix
XML API	Devices send login and logout messages to the firewall over HTTP	Anything not otherwise integrated

Syslog listening also deletes stale mappings on logout, which matters where IP addresses change often.

Choosing a Mapping Method

If you have…	Use
GlobalProtect VPN clients	GlobalProtect
Web clients that don’t log in to the domain	Captive Portal
Non-Windows systems, wireless, 802.1x, proxies	Syslog listener
Exchange servers, domain controllers, eDirectory	Agent: server monitoring
Windows file and print shares	Agent: session monitoring
Multi-user terminal servers	Terminal Services agent
Windows clients that change IP addresses often	Agent: client probing
Devices and apps not integrated with User-ID	XML API

From Login to Policy Match

What happens when userA logs in to a domain-joined laptop and sends traffic:

1. **Login recorded** – the domain controller logs the username and IP address.
2. **Zone check** – is User-ID enabled on the source zone? If not, stop here.
3. **Agent query** – the firewall asks its integrated or Windows-based agent for the mapping.
4. **User mapping** – the IP address is associated with userA.
5. **Group mapping** – LDAP tells the firewall which groups userA is in.
6. **Policy match** – traffic from that IP is checked against Security policy using the user and groups.



LESSON 3

Configuring the User-ID Agent

Configuring User-ID: Four Steps



Enable User-ID by zone

Turn on User Identification for the zones where users originate.



Configure user mapping methods

Agents, GlobalProtect, syslog, or the XML API, depending on the environment.



Configure group mapping

Optional, but group-based rules are far easier to maintain than per-user rules.

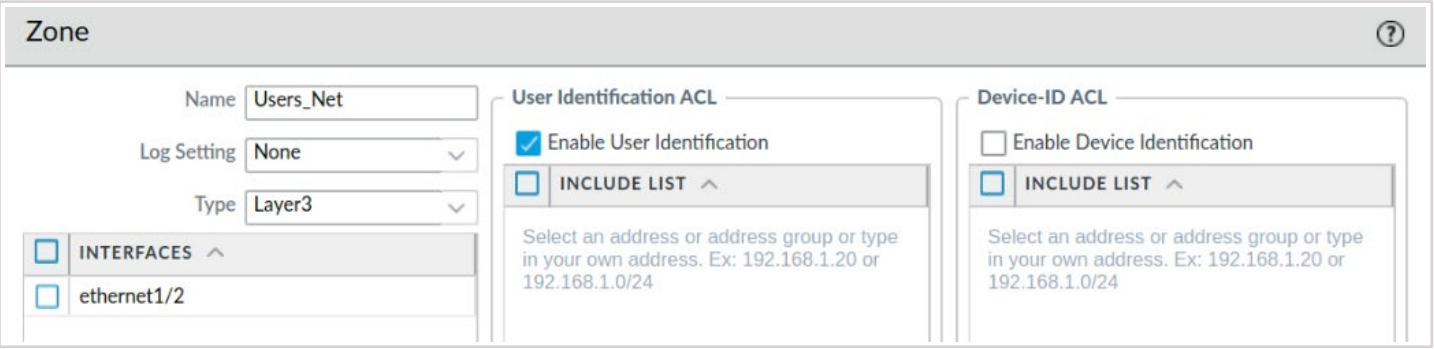


Use users and groups in policy

Add them to the Source User field of Security policy rules.

Enable User-ID Per Zone

- Select **Enable User Identification** on the zone where user traffic **originates**.
- User-ID only tracks users in the **source zone** of a session.
- By default every subnet in the zone is mapped; narrow it with the **Include List** and **Exclude List**.



Network > Zones > zone

SECURITY FOCUS

Enable User-ID only on internal zones. Never enable it on a zone facing the internet.

Why it matters: The firewall would try to identify every address on the internet, and probing would reach out to untrusted hosts.

Integrated Agent Setup Steps

Most settings live under Device > User Identification > User Mapping:

1. On the domain controller, create a **service account** for the agent.
2. Define the **monitored servers** on the firewall.
3. Add the service account in `domain\username` format.
4. Optionally enable **session monitoring** and **WMI probing**.
5. Commit and **verify** the connection status.



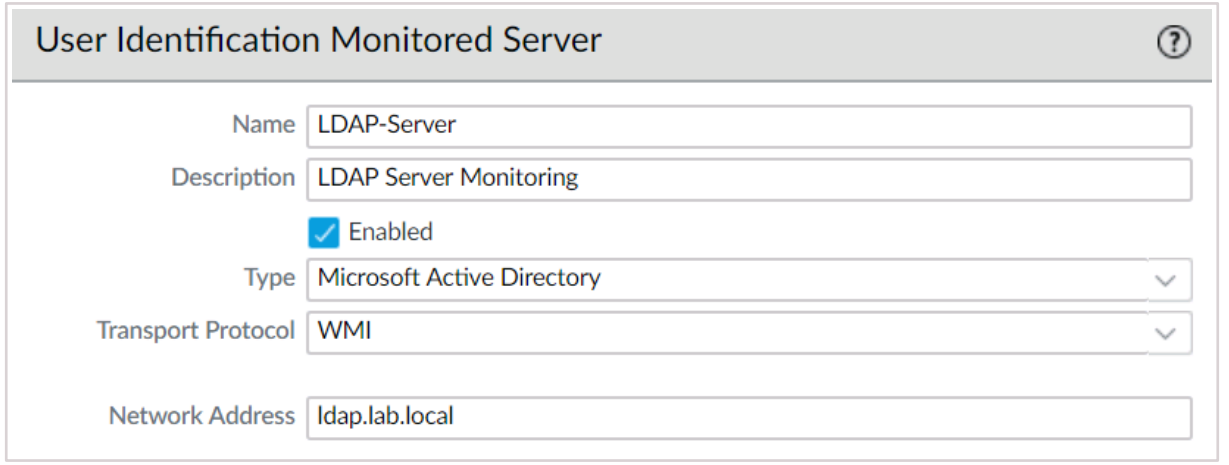
SECURITY FOCUS

Domain Admins, or Server Operators plus Event Log Readers, will work. Best practice is a restricted account with only the rights it needs.

Why it matters: The agent's password lives on the firewall. If it's a Domain Admin, one leak owns the domain.

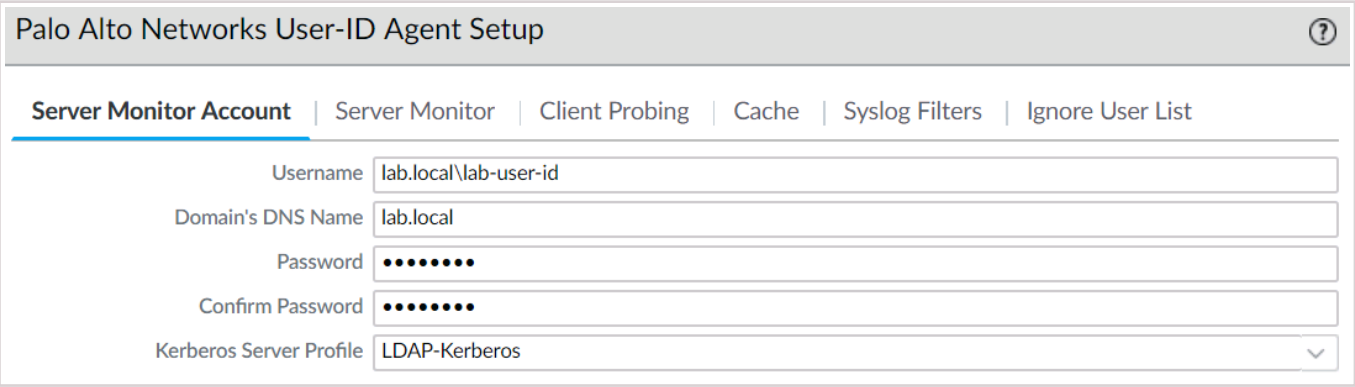
Define the Monitored Servers

- **Discover** finds domain controllers through DNS, using the domain set in Device > Setup > Management.
- **Add** servers manually; this is required for Exchange, eDirectory, and syslog senders.
- Choose the server **Type** and **Transport Protocol** (WMI or WinRM).



Define the User-ID Agent Account

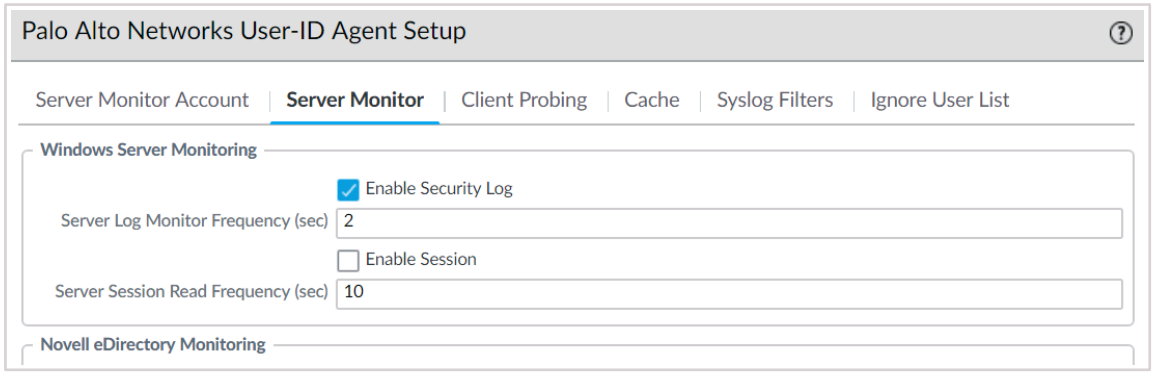
Device > User Identification > User Mapping > Server Monitor Account



- Enter the account as `domain\username`.
- **Domain's DNS Name** identifies the domain the agent monitors.
- Required for monitoring domain controllers and Exchange servers.

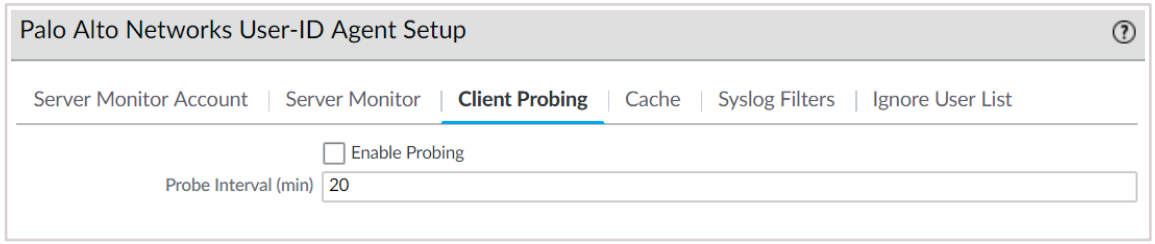
Optional: Session Monitoring and WMI Probing

Server Monitor tab



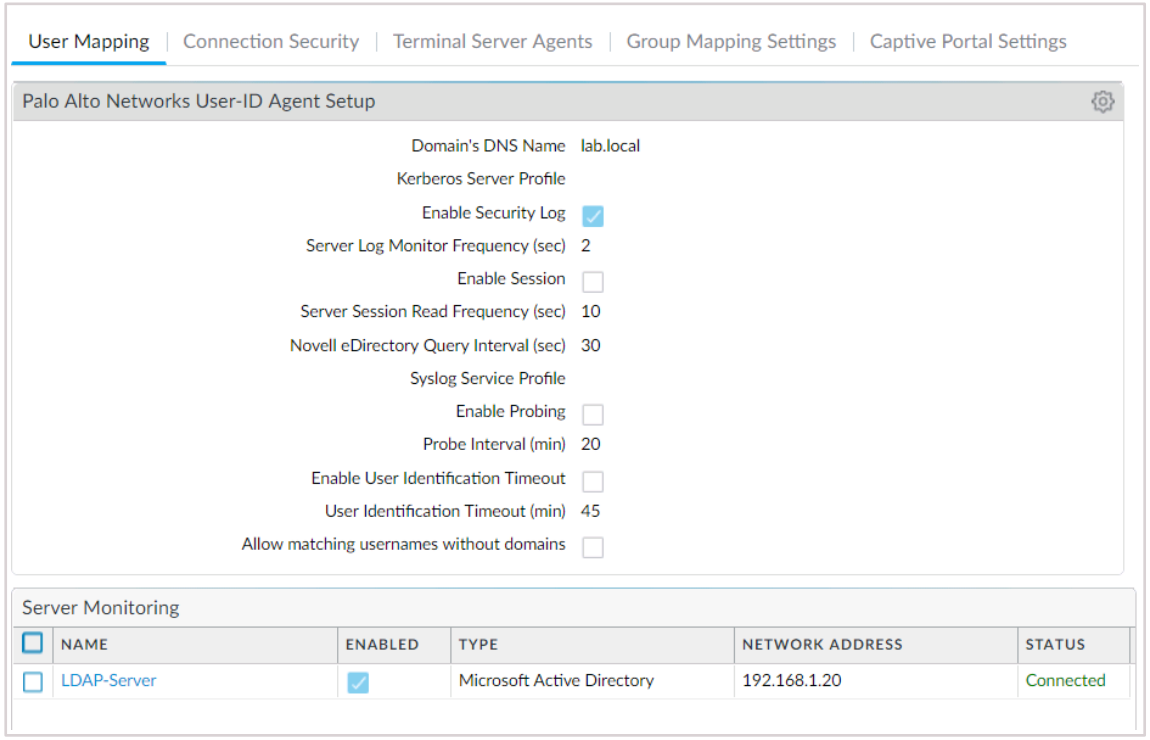
- **Enable Security Log** is on by default.
- **Enable Session** turns on session monitoring.

Client Probing tab



- **Enable Probing** and set the interval in minutes.
- The integrated agent supports **WMI probing only**.

Verify Agent Connection Status



After you commit, every monitored server should show **Connected**.

```
show user server-monitor state all
show user ip-user-mapping all
```

Not connected? Check the **service account**, that the domain **audits logons**, and the path from the firewall to the server.

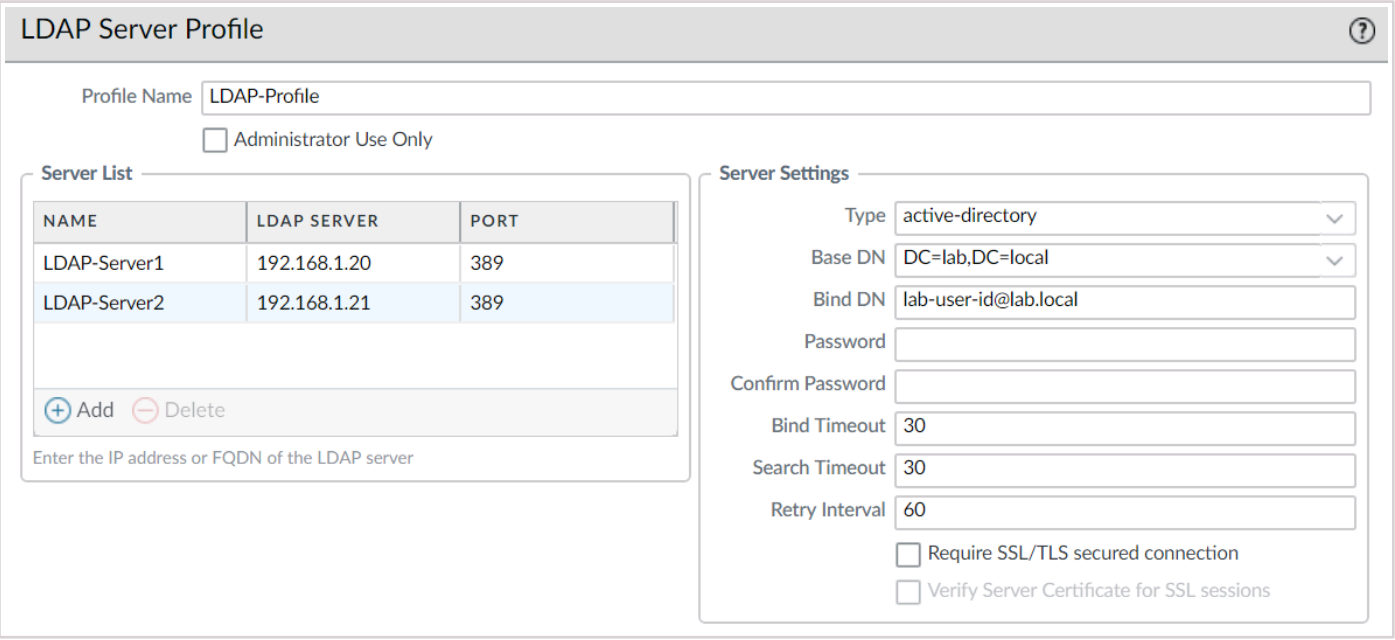
LESSON 4

Group Mapping



LDAP Server Profile

Device > Server Profiles > LDAP tells the firewall where the directory is and how to search it.



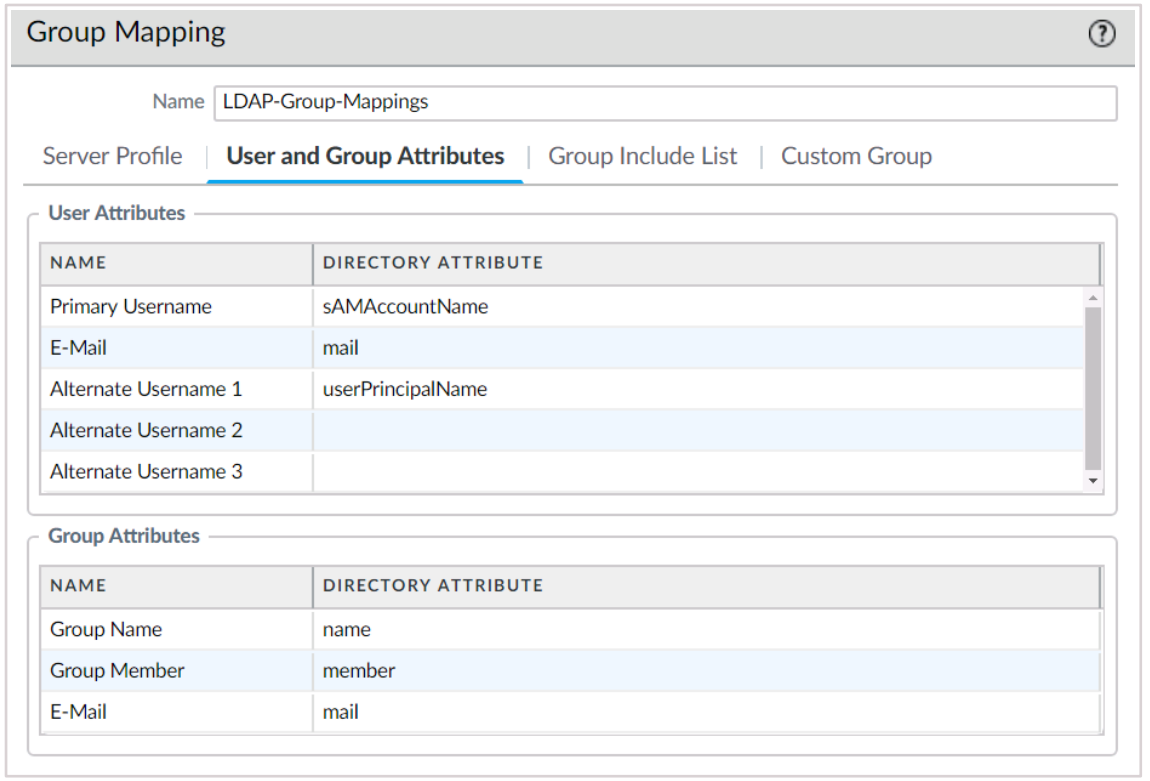
- **Type** sets the directory, such as active-directory.
- **Base DN** is where the search starts in the tree.
- **Bind DN** and password are the account the firewall reads with.
- Use port `3268` (Global Catalog) for universal groups.

Keep Require SSL/TLS secured connection selected in production so directory credentials aren't sent in the clear.

Group Mapping: Server Profile and Attributes

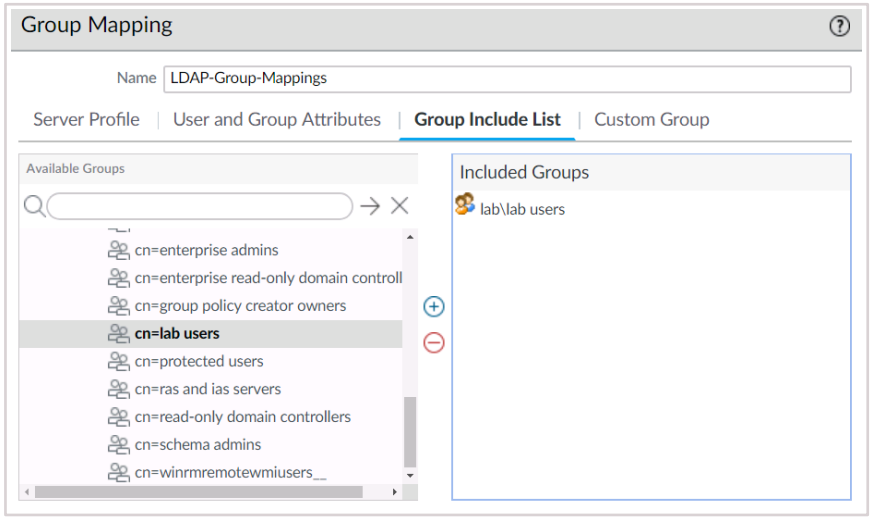
Device > User Identification > Group Mapping Settings > Add

- Select the **LDAP Server Profile**; group and user object fields fill in automatically.
- Set the **Primary Username** attribute used in logs, reports, and policy.
- Add an email and up to **three alternate** username formats.
- Leave **User Domain** blank unless you must override the detected domain.



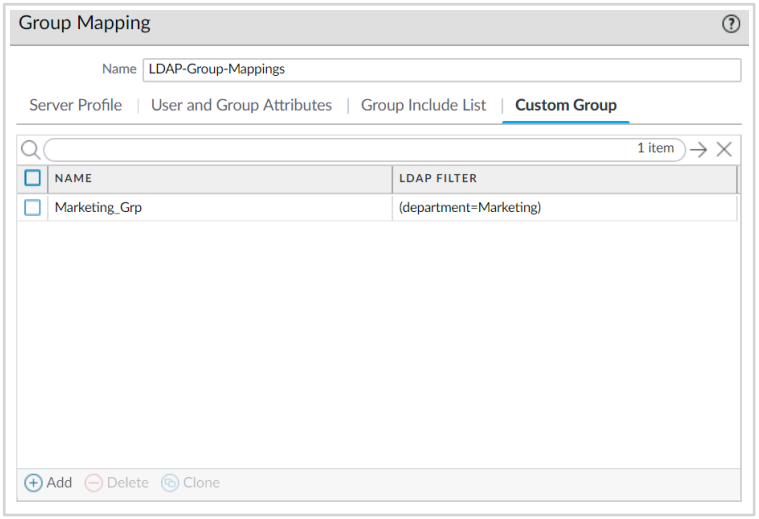
Group Include List and Custom Groups

Group Include List



- Only **included groups** appear in policy drop-downs.
- Include nothing, and every group is available.

Custom Group



- Builds a group from an **LDAP filter**, such as `(department=Marketing)`.
- No directory admin needed; usable in policy, logs, and reports.

LESSON 5

User-ID in Security Policy



The Source User Field

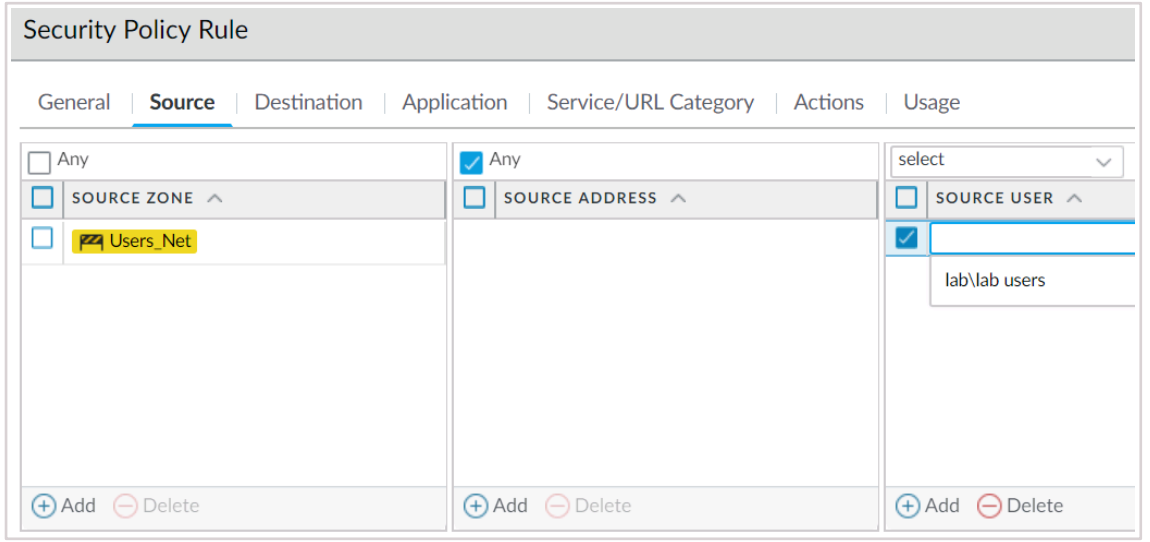
In a Security policy rule, users and groups go in the Source User field:

Option	Matches
any	Any user, whether User-ID identified them or not
pre-logon	GlobalProtect users before they log in to Windows
known-user	Any user or group User-ID has identified
unknown	Traffic where User-ID couldn't identify the user
select	Specific users or groups, including Dynamic User Groups

You can only select users and groups the firewall already knows about.

Writing User-Based Rules

- **Source Address** and **Source User** are evaluated with a logical **AND**; both must match.
- Make them too specific and you block traffic you meant to allow.
- Prefer **groups over users**: membership changes need no rule edit and no commit.



Troubleshooting tip: a user rule that never matches usually means no mapping exists. Check the User-ID log first.

Verifying User-ID

Three places to confirm the firewall knows who is who:

- **Monitor > Logs > User-ID** – every mapping the firewall has learned and where it came from.
- **Monitor > Logs > Traffic** – add the **Source User** column, then filter by user or app.
- **CLI** – list current mappings and group membership.

```
show user ip-user-mapping all
show user group list
( app eq instagram-base ) and ( user.src eq 'chicago\sholmes' )
```

Dynamic User Groups (DUGs)

- A **Dynamic User Group** gets its members from **tags**, not from the directory.
- Only tagged usernames are members; tag or untag a user and their access changes **without a commit**.
- Used as a Source User in Security, Authentication, and Decryption policy.
- Tags come from the web interface, **auto-tagging** in a Log Forwarding profile, or the XML API.



Static vs. dynamic

The DUG object and the rule using it need a commit once. After that, membership is runtime data that changes on its own.

DUG Use Cases

Respond to user behavior

- Firewall logs feed a SIEM, UEBA, or SOC tools
- Analysis **tags** a user whose activity looks risky
- The tag drops them into a restricted DUG automatically

Time-based access

- Create a policy that grants access to DUG members
- Give a contractor a tag with a **timeout**
- When the tag expires, membership and access end on their own

The pattern: write the rule once for the group, then let tags decide who is in it.

Security Focus: Identity Is a Control

SECURITY FOCUS

Least privilege for the **agent service account**; never a Domain Admin in production.

User-ID on **internal zones only**; never on an internet-facing zone.

Decide what **unknown** users get, rather than letting them fall through to an allow rule.

Keep LDAP connections on **SSL/TLS** so bind credentials aren't exposed.

Why it matters: User-based rules are only as trustworthy as the mappings behind them. A wrong or stale mapping hands one user's access to another.

Lab 11: Controlling Access with User-ID

NETLAB+ · PAN-OS 11 Firewall Essentials · baseline edu-210-11.0a-11.xml



- Review the **Acquisition-Allow-All** rule and the two Application Groups.
- Enable **User Identification** on the Acquisition zone.
- Rename the rule to **Allow-Corp-Apps** and limit it to Allowed-Corp-Apps.
- Create **Allow-Mktg-Apps** for the marketing group, and **Deny-All-Others** at the bottom.
- Generate traffic, then use the User-ID and Traffic logs to answer the lab questions.

Log-in details are in the Lab Settings table of the lab guide.

Lab 11 Tips

- **Don’t skip enabling User-ID** – it’s only in the Detailed steps (2.4). High-Level users must do it anyway.
- **Be patient** – let the script finish, then allow 3 to 6 minutes for the Traffic log to update.
- **Retype the filter quotes** – the guide’s `user.src` filters use curly quotes, which break when pasted.
- **Ignore section 2.3’s first line** – the packet-capture sentence is left over from another lab.



Same host, two names

The guide calls the traffic source both **Server-Extranet** and **Extranet-Server**. In Remmina it’s Server-Extranet.

Unit 12 Homework

Always check Blackboard for assignments and when they are due.



- **Unit 12 Lab:** NETLAB+ Lab 11 – Controlling Access to Network Resources with User-ID
- **Unit 12 Video:** watch the video linked in the Unit 12 learning plan
- **Unit 12 Quiz**
- **Quiz 3:** Units 8 – 12

Key Takeaways

- User-ID maps IPs to users and users to groups, so policy can follow people.
- Server monitoring is the base method; add others to fill the gaps.
- Enable User-ID per internal zone, and run the agent with a least-privilege account.
- Group mapping through LDAP lets one rule cover a whole department.
- Source User ANDs with Source Address; DUGs change access without a commit.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 12 · Controlling Access to Network Resources with User-ID

MID-STATE TECHNICAL COLLEGE